

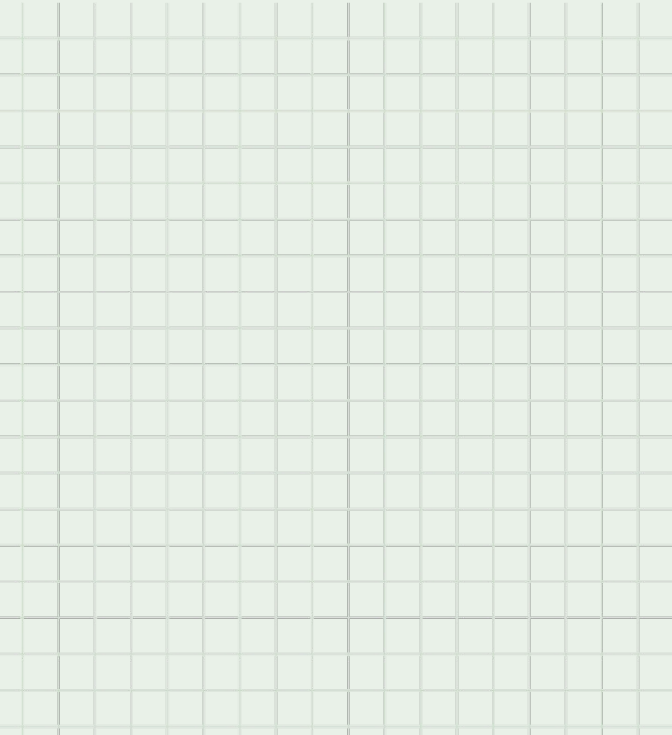
EMPIRICAL

No Breach Required:

\$52 Million in Cybersecurity Fraud Settlements
Built on Paperwork, Not Incidents

Max Voldman Partner, Whistleblower Partners LLP
Michael Roytman CTO, Empirical Security

Roadmap



- **What is the False Claims Act?**
- What Are We Representing?
- Benchmarking Risk
- Benchmarking Yourself
- Representation Strategies

Double Edged Sword of Measurement

What is the False Claims Act

A law that allows whistleblowers to sue in the name of the U.S., alleging fraud against the government.

**Passed during the Civil War;
predicates go back to 7th-century Kent.**

Significantly amended in 1986.



Government involvement varies

**Whistleblowers receive
15% – 30% of the
recovery**

The FCA's Application

Bulk of the Enforcement Actions are in Healthcare (Medicare, most commonly)

Cyber is a newer initiative—the DOJ launched it in 2021.

Trump's DOJ has reiterated those goals.



The first cyber settlement was with Cisco (\$8.6 million) and involved a software vulnerability in video monitoring devices.

\$8.6m

In FY 2025, \$52 million in cyber-related settlements were secured.

\$52m

Recent Cyber Settlements

Health Net Federal Services Inc. (\$11 million)

Crossover of healthcare and cyber industries.

A military benefits contract settled allegations that it did not follow TRICARE's cyber requirements in its contracts.

Failed to conduct required vulnerability scanning and ignored audit and internal warnings regarding cybersecurity deficiencies.

No whistleblower; DOJ-initiated case.

\$11m

Illumina (\$10 million)

Sold genomic sequencing medical devices.

Falsely certified compliance with cybersecurity standards published by the International Organization for Standardization (ISO) and the National Institute of Standards and Technology (NIST).

No breach.

Whistleblower-initiated.

\$10m

Recent Cyber Settlements

Raytheon (\$8.4 million; successor liability)

Another violation of NIST standards, this time in a DOW contract. Whistleblower-initiated.

\$8.4m

Morse (\$4.8 million)

A cloud services defense contractor.

Allegations that it failed to implement required NIST SP 800-171 controls under Department of War contracts, submitted false Supplier Performance Risk System (SPRS) scores, and used non-compliant cloud services.

\$4.8m

Penn State (\$1.25 million)

Failed to comply with NIST requirements on a

NASA research grant.

Also used a cloud vendor that did not meet FedRAMP requirements.

A grant, not a contract.

No breach.

\$1.25m

Representations to the U.S. Are Key

The DOJ reiterates that it is targeting misrepresentations, not data breaches.

A breach will not necessarily lead to liability, and not all breaches lead to FCA liability.

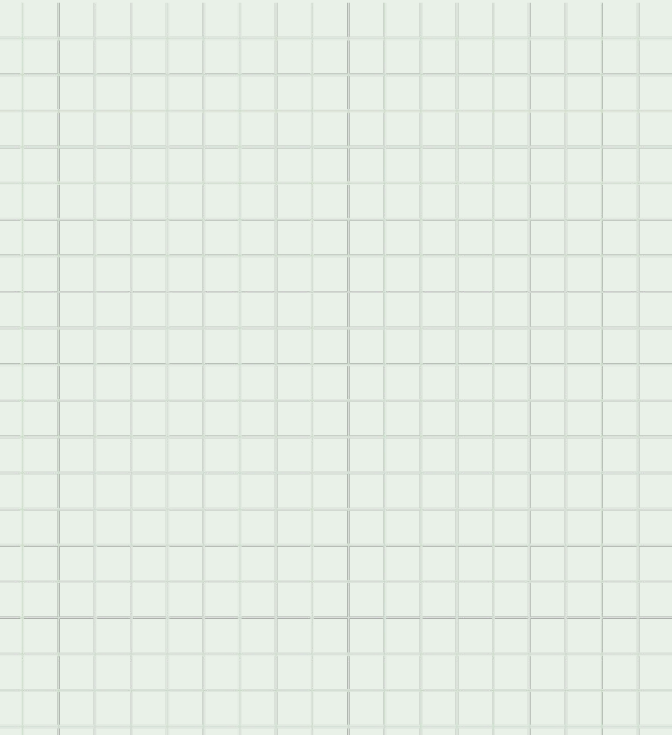
Knowledge (which does not require intent) is a required element of the FCA.

Mistakes are not actionable under the FCA; knowing misrepresentations are.

Those doing business with the government should be laser-focused on the truthfulness of their statements to the government.

What a company or individual did or did not tell the government can make or break a case.

Roadmap



- What is the False Claims Act?
- **What Are We Representing?**
- Benchmarking Risk
- Benchmarking Yourself
- Representation Strategies

Double Edged Sword of Measurement

Representations?

In the context of the Department of War (DoW), SPRS stands for the Supplier Performance Risk System.

It is the official procurement risk analysis tool and database used to track, score, and evaluate defense contractors based on cybersecurity compliance, delivery performance, and product quality



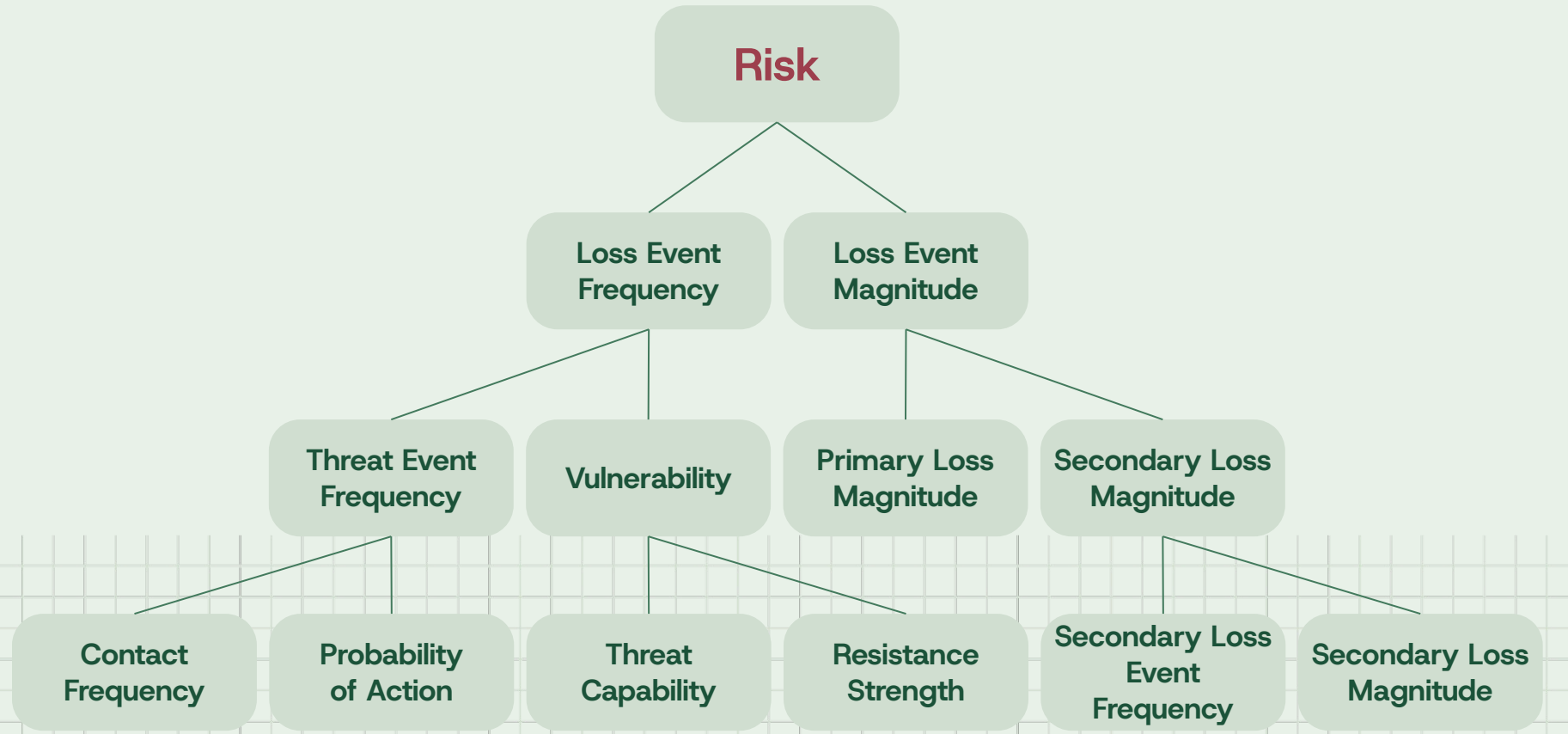
Representations?

NIST SP 800-171 is a federal cybersecurity framework outlining security requirements for protecting Controlled Unclassified Information (CUI) in non-federal systems.

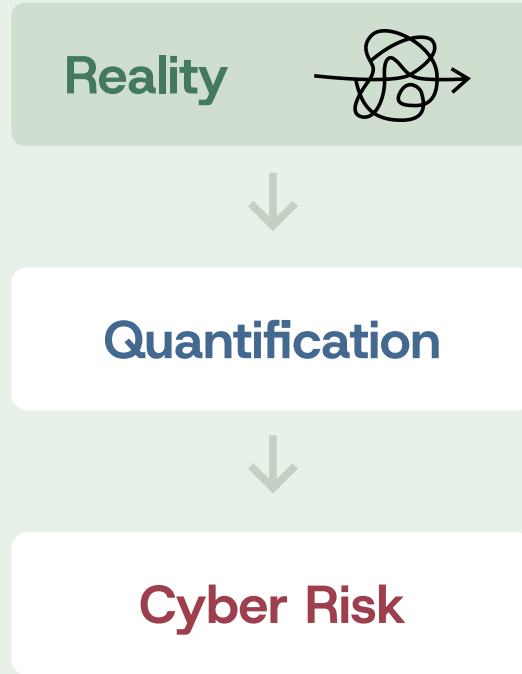
Compliance with this standard is mandatory for defense contractors, federal agencies, and organizations in the federal supply chain to ensure sensitive government data remains secure.



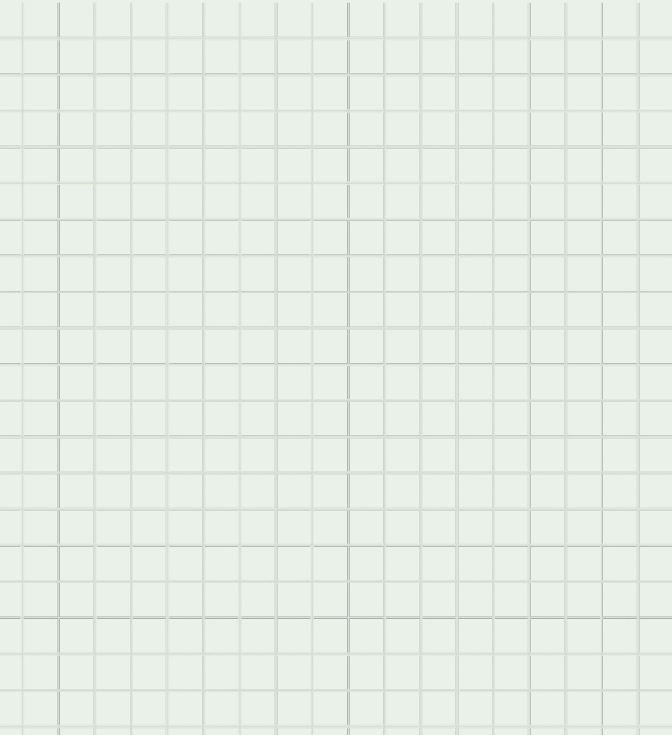
What Are We Representing?



Where it all fits in



Roadmap

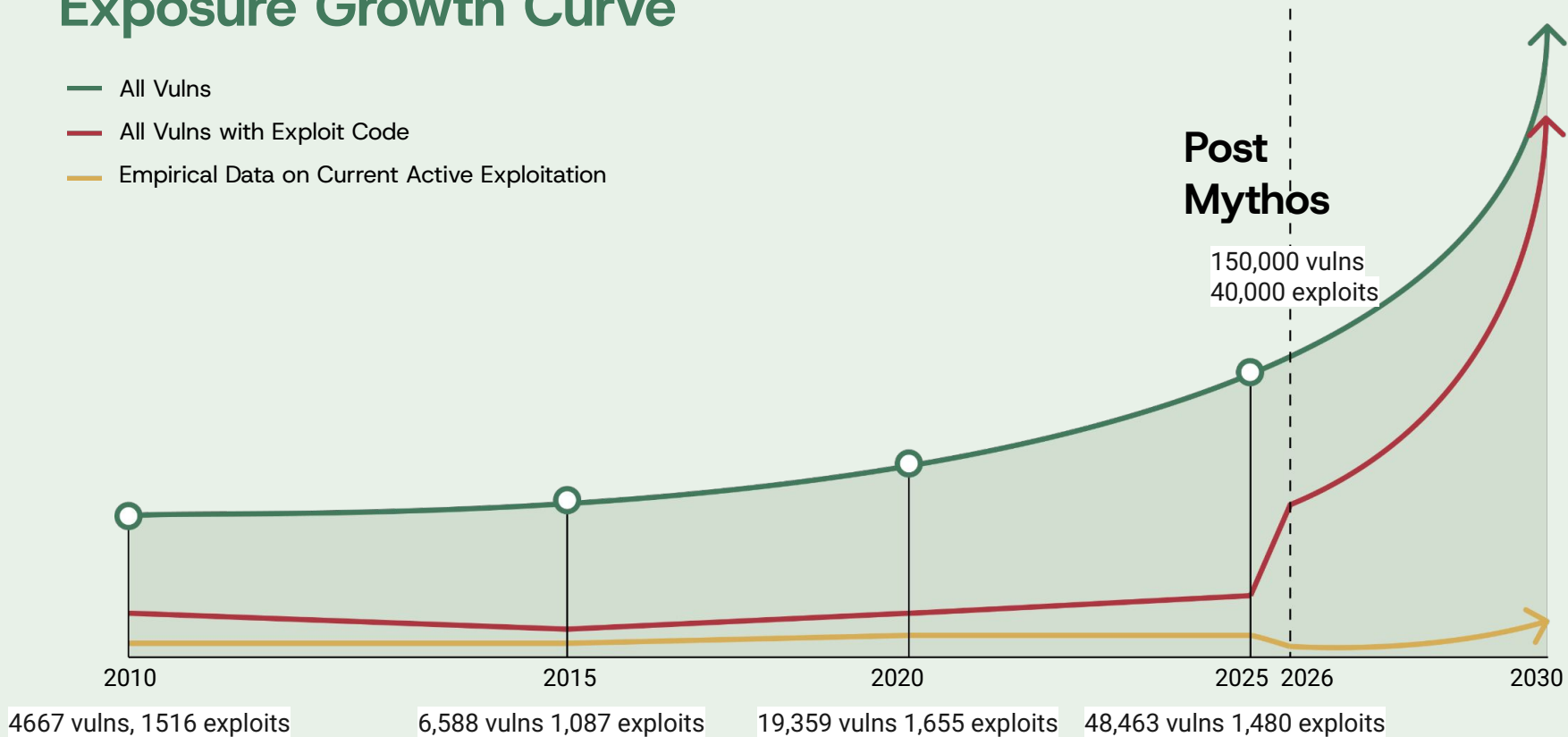


- What is the False Claims Act?
- What Are We Representing?
- **Benchmarking Risk**
- Benchmarking Yourself
- Representation Strategies

Double Edged Sword of Measurement

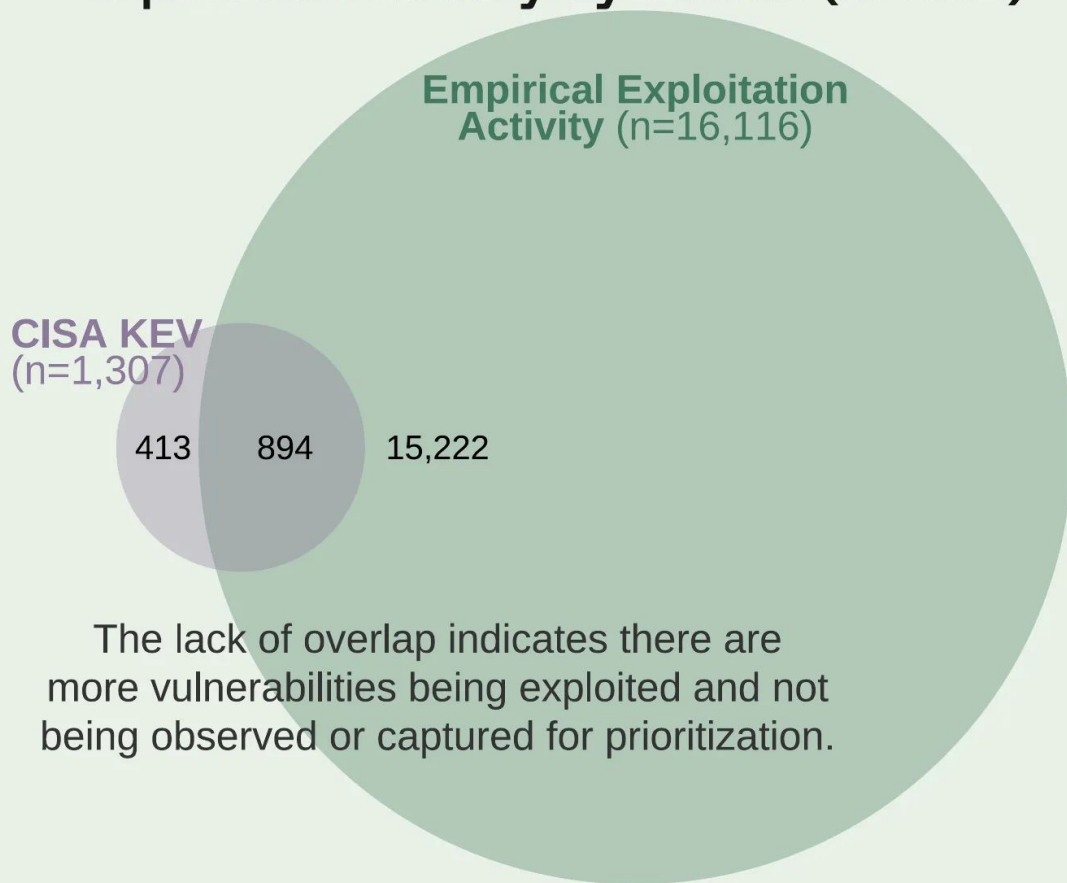
Exposure Growth Curve

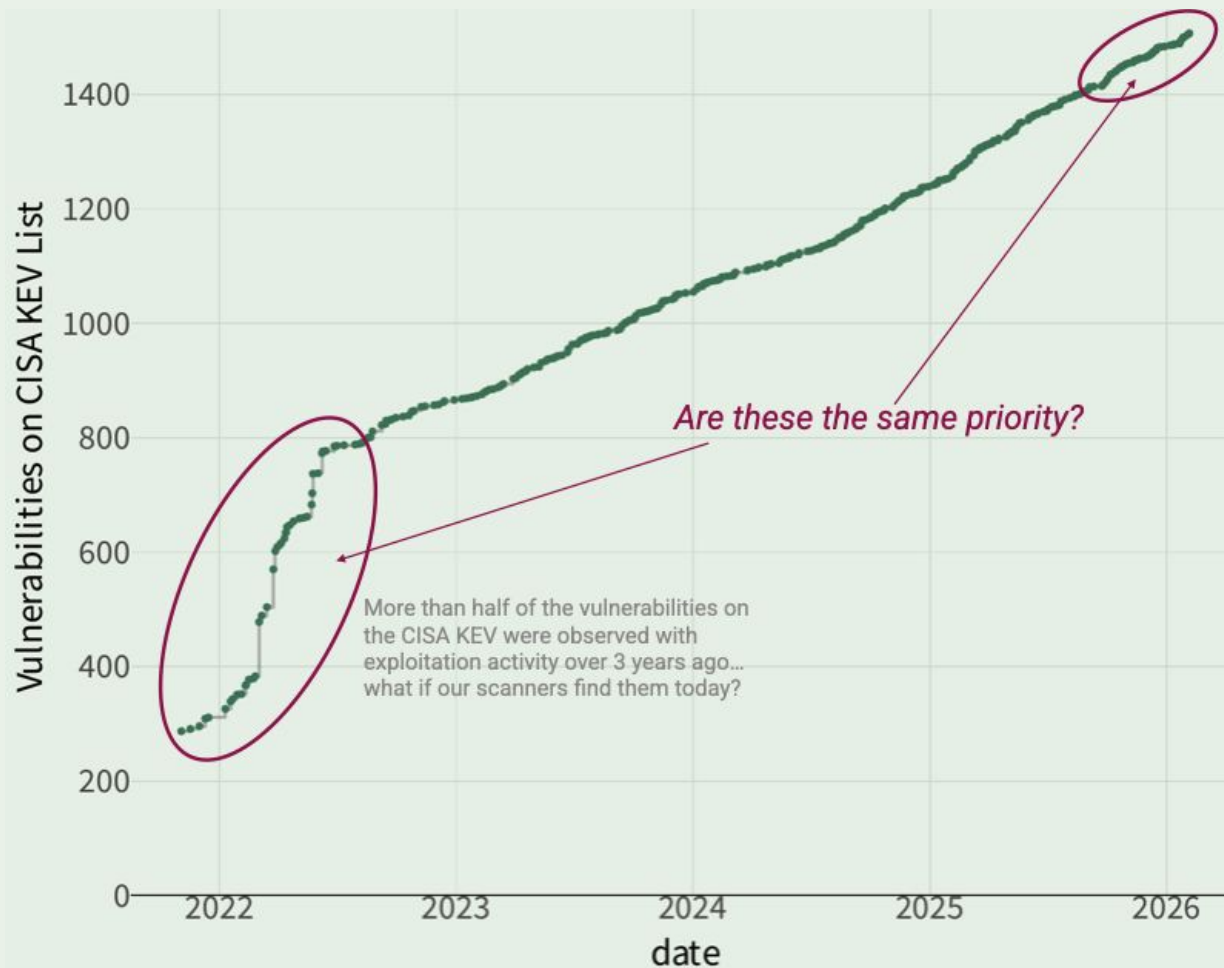
- All Vulns
- All Vulns with Exploit Code
- Empirical Data on Current Active Exploitation



Exploitation Activity by Source (all time)

KEV covers
roughly 8%
of observed
exploitation

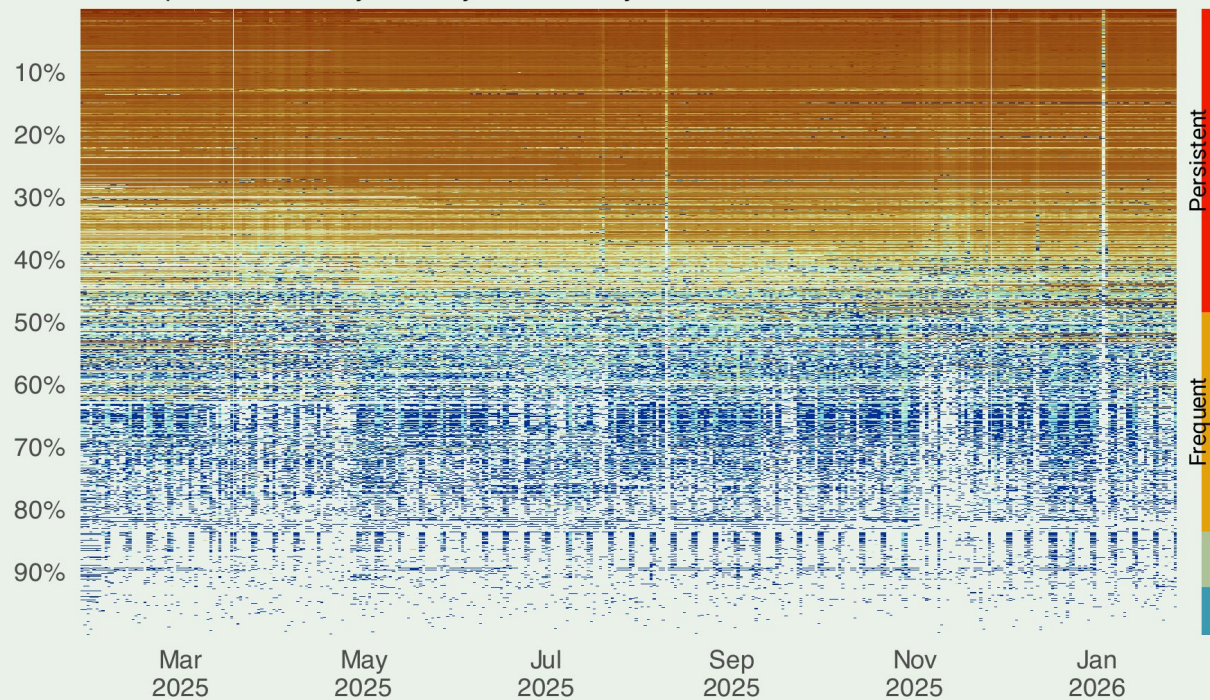




It Boils Down to Bursts and Blast Radius

Exploitation cannot be represented with a single timestamp.

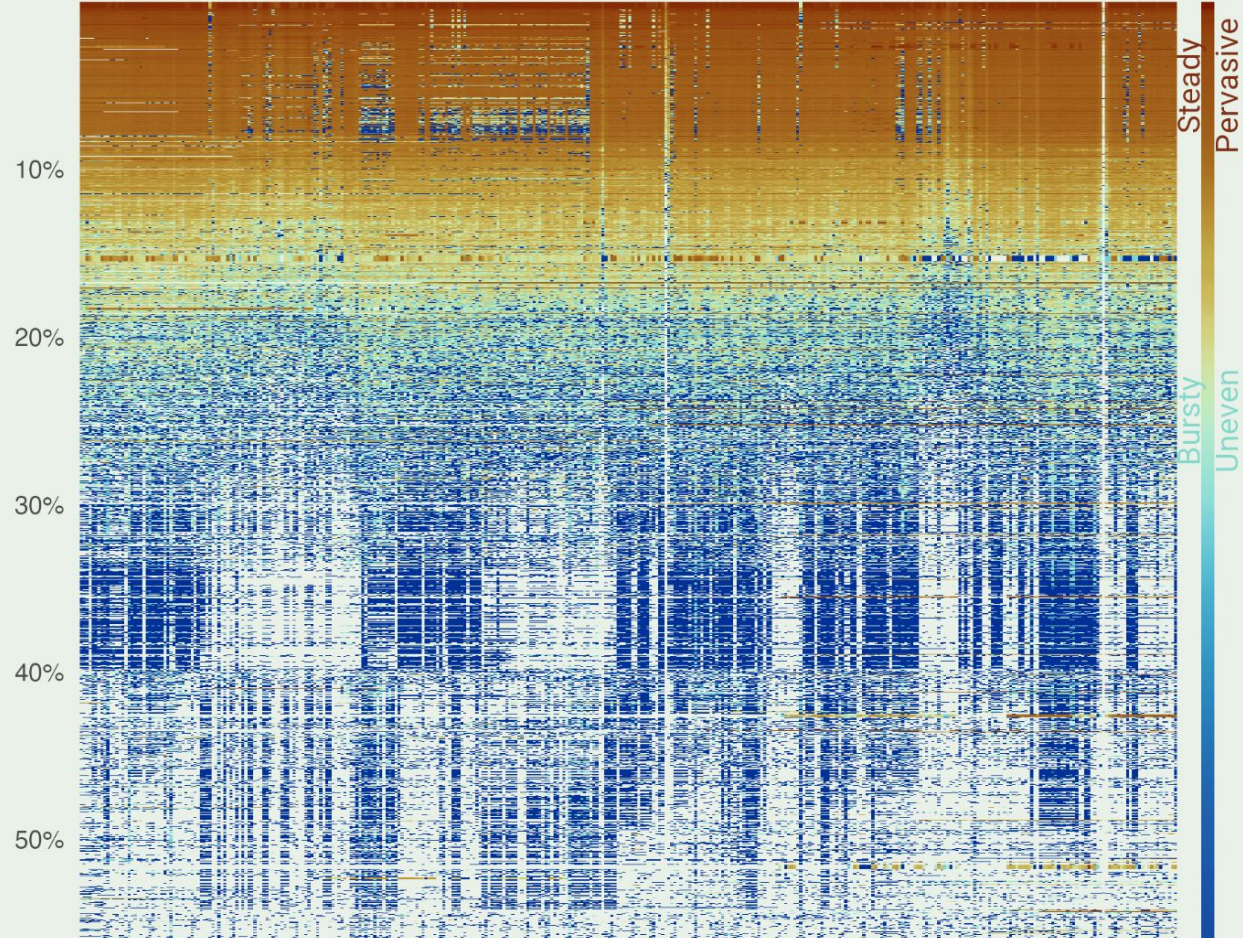
Real exploitation activity is bursty and unevenly distributed

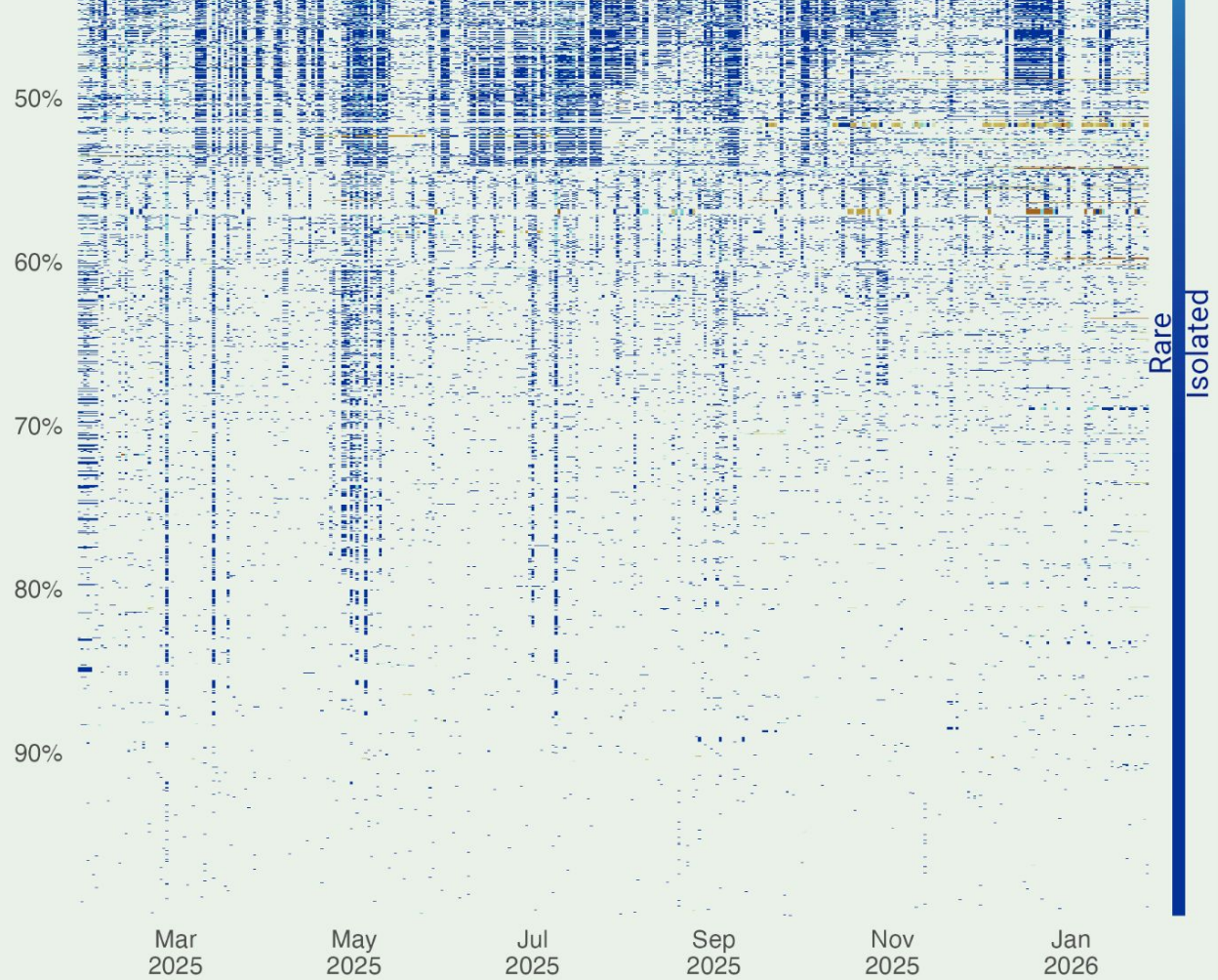


It Boils Down to Bursts and Blast Radius

Exploitation cannot be represented with a single timestamp.

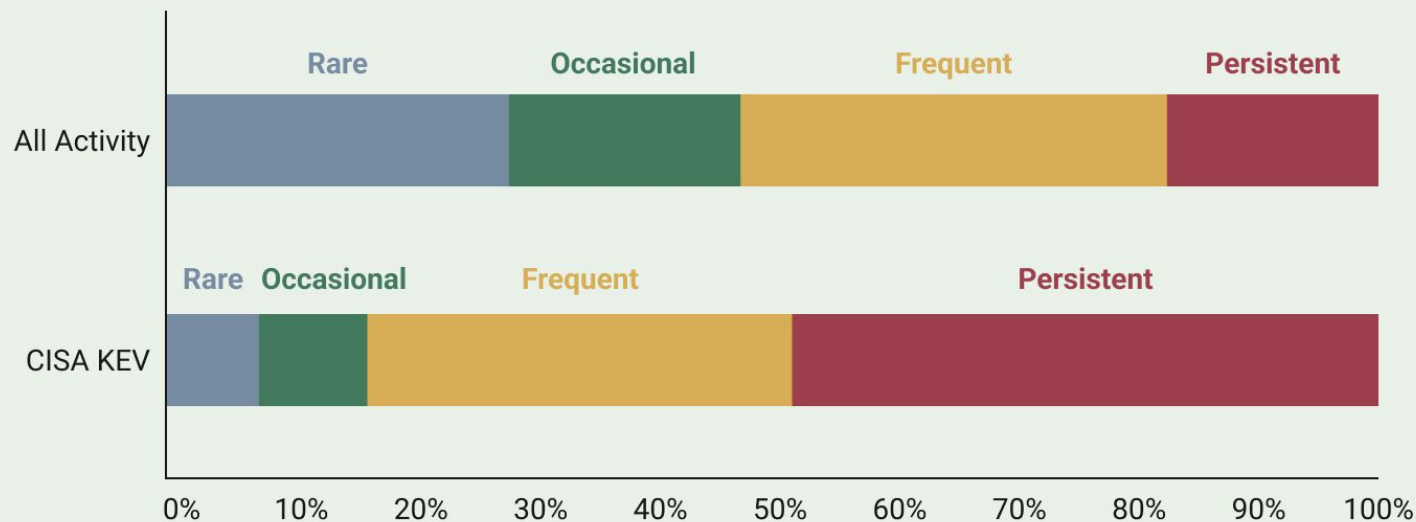
Real exploitation activity is bursty and unevenly distributed





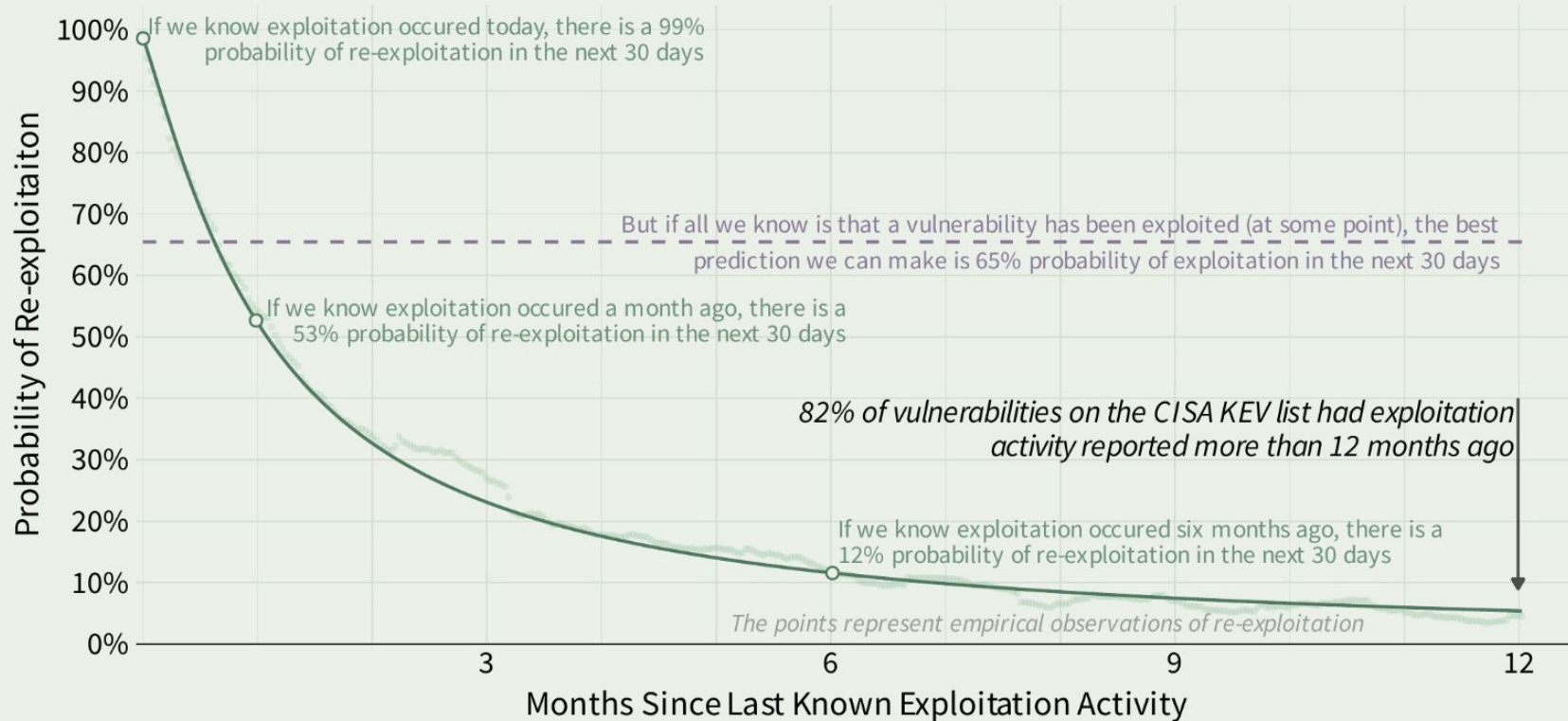
EMPIRICAL

All Activity vs CISA KEV

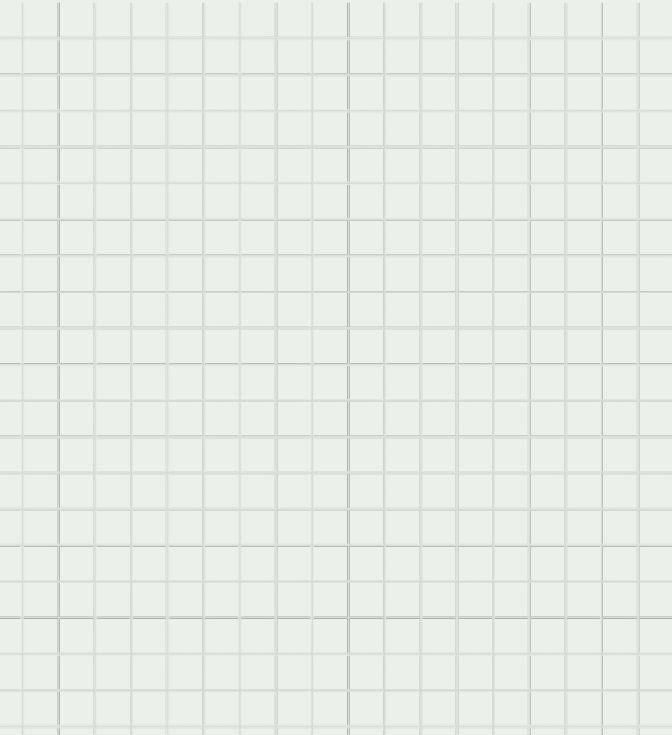


How Recency of Exploitation Predicts Re-Exploitation

If all we know is that exploitation has occurred at some point, the best predictive model of re-exploitation in the next 30 days is a flat 65%. But if we know how recently a vulnerability has exploitation activity we can make a much more informed and accurate prediction.



Roadmap

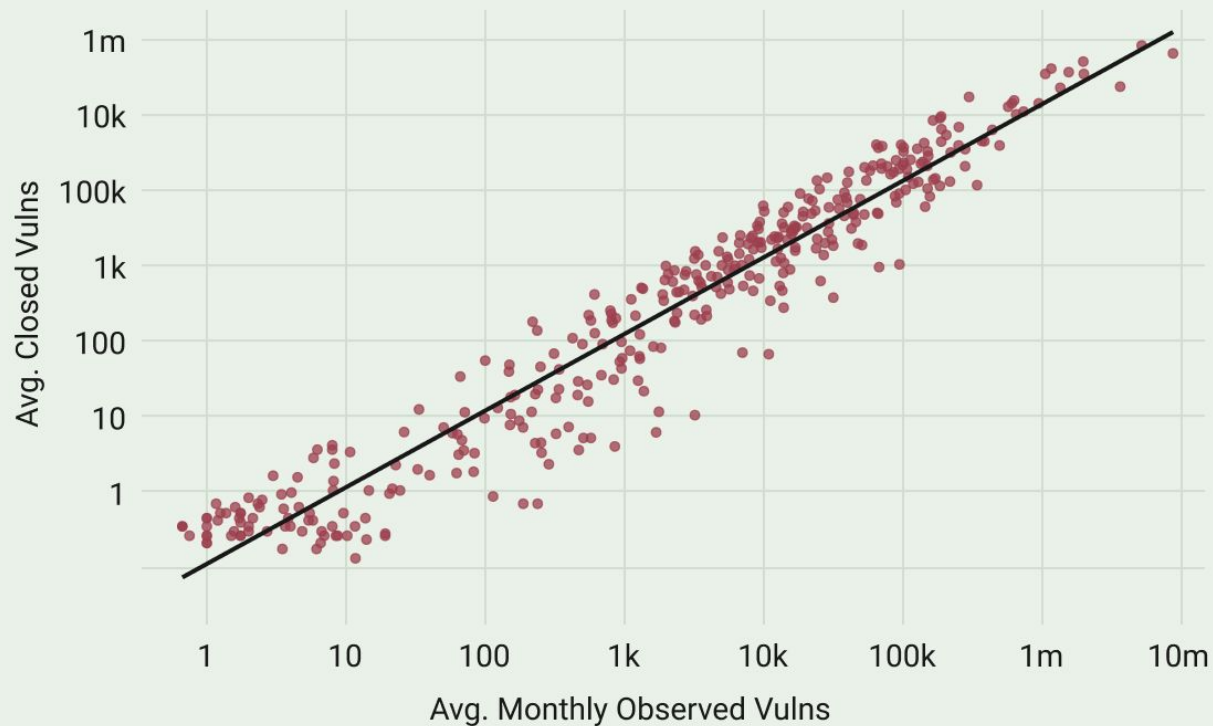


- What is the False Claims Act?
- What Are We Representing?
- Benchmarking Risk
- **Benchmarking Yourself**
- Representation Strategies

Double Edged Sword of Measurement

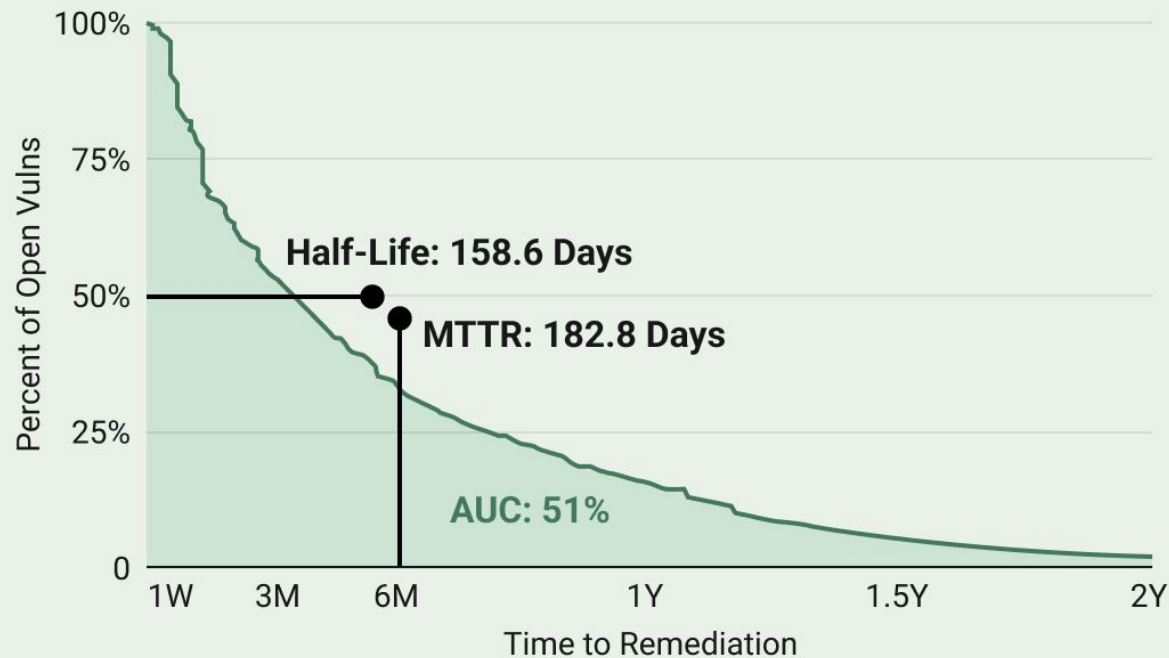
EMPIRICAL

Avg. Monthly Observed vs. Closed Vulnerabilities per Firm



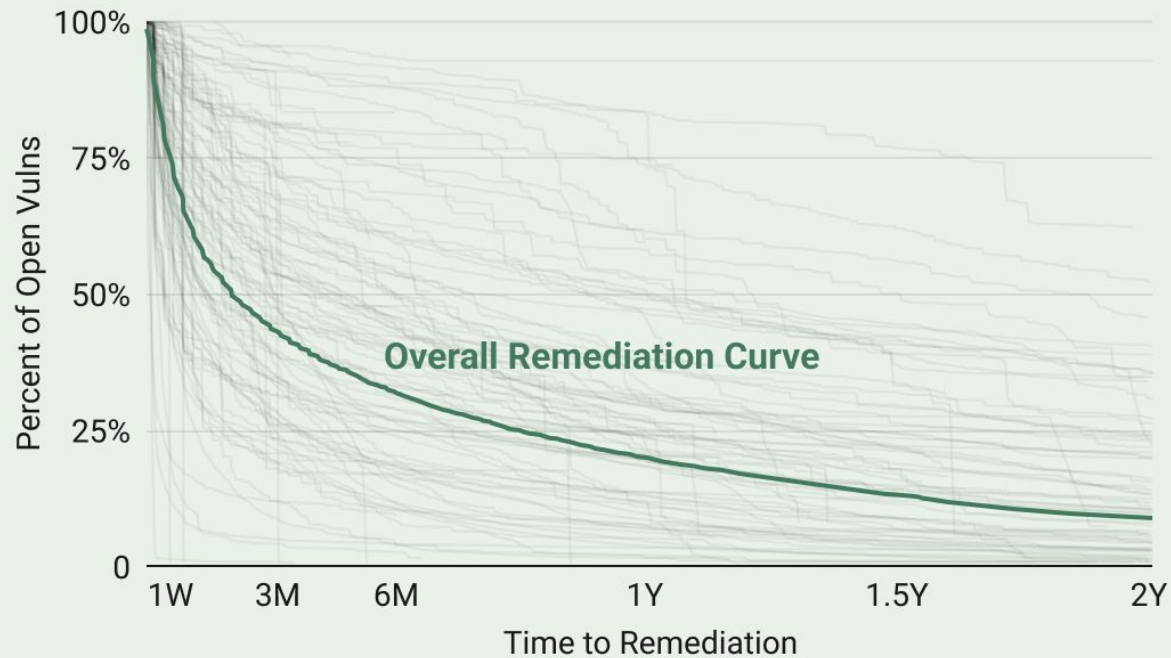
EMPIRICAL

Survival analysis curves for vulnerability remediation timelines, Fig. 1

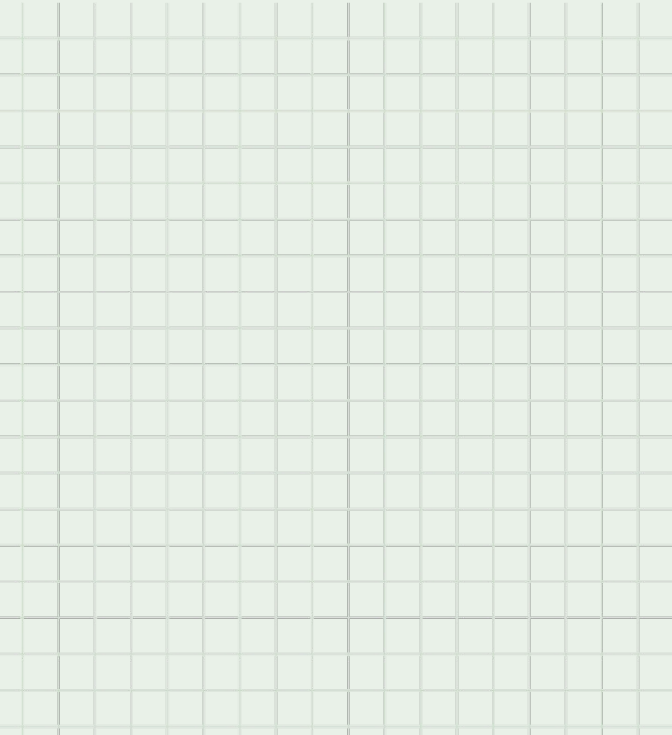


EMPIRICAL

Survival analysis curves for vulnerability remediation timelines, Fig. 2



Roadmap



- What is the False Claims Act?
- What Are We Representing?
- Benchmarking Risk
- Benchmarking Yourself
- **Representation Strategies**

Double Edged Sword of Measurement

Project Glasswing

// Use EPSS to prioritize the rest. Exploit Prediction Scoring System (EPSS) provides a daily-updated probability that a given Common Vulnerability and Exposure (CVE) will be exploited in the next 30 days. Patching the KEV list first and then everything above a chosen EPSS threshold will help you turn thousands of open CVEs into a manageable queue."

AI models are very effective at recognizing the signatures of known, already-patched vulnerabilities in unpatched systems. Reversing a patch into a working exploit is exactly the kind of mechanical analysis at which these models excel. This means that the window between a patch being published and an exploit becoming available is shrinking.

- *Patch everything on the CISA Known Exploited Vulnerabilities (KEV) catalog immediately.* This catalog contains vulnerabilities that are confirmed to be under active exploitation. Anything on this list which is reachable from a network should be treated as an emergency.
- *Use EPSS to prioritize the rest.* Exploit Prediction Scoring System (EPSS) provides a daily-updated probability that a given Common Vulnerability and Exposure (CVE) will be exploited in the next 30 days. Patching the KEV list first and then everything above a chosen EPSS threshold will help you turn thousands of open CVEs into a manageable queue.
- *Reduce time-to-patch on internet-exposed systems.* We recommend patching internet-facing applications within 24 hours of an exploit becoming available, and within days for

Measuring Performance of Prioritization

Coverage

The percentage of exploited vulnerabilities fixed given a remediation strategy.

Efficiency

The percentage of effort fixing vulnerabilities that are exploited.

Effort

The percentage of vulnerabilities that are required to be fixed given a remediation strategy.

Threshold

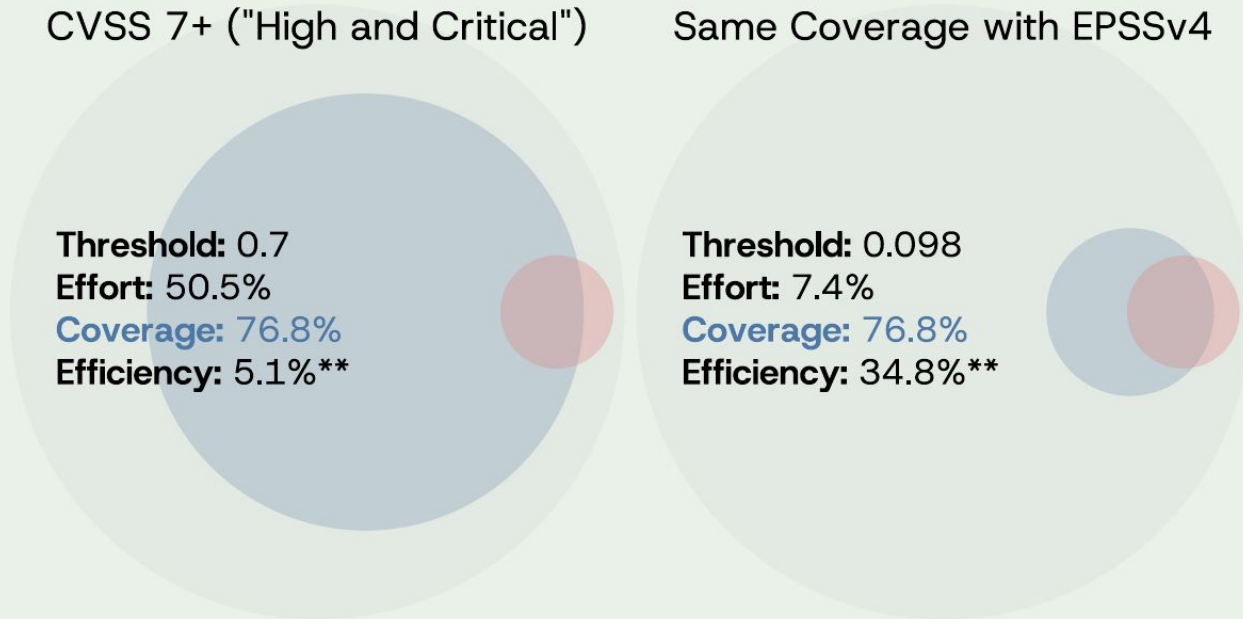
The policy that requires a vulnerability to be fixed at that score or higher.

CVSS 7+ ("High and Critical")

Threshold: 0.7
Effort: 50.5%
Coverage: 76.8%
Efficiency: 5.1%**

Same Coverage with EPSSv4

Threshold: 0.098
Effort: 7.4%
Coverage: 76.8%
Efficiency: 34.8%**



Measuring Performance of Prioritization

Coverage

The percentage of exploited vulnerabilities fixed given a remediation strategy.

Efficiency

The percentage of effort fixing vulnerabilities that are exploited.

Effort

The percentage of vulnerabilities that are required to be fixed given a remediation strategy.

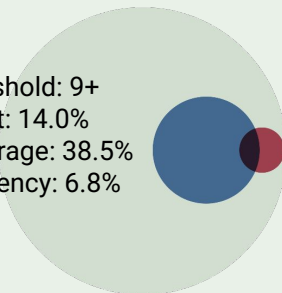
Threshold

The policy that requires a vulnerability to be fixed at that score or higher.

CVSS Score

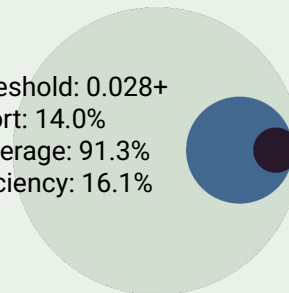
CVSS
9+
Critical

Threshold: 9+
Effort: 14.0%
Coverage: 38.5%
Efficiency: 6.8%



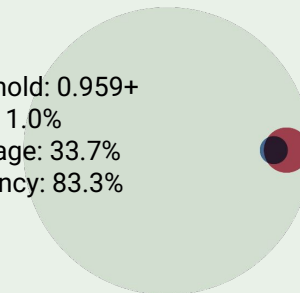
Same Effort

Threshold: 0.028+
Effort: 14.0%
Coverage: 91.3%
Efficiency: 16.1%



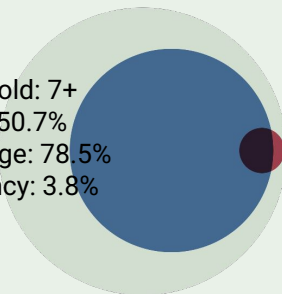
Same Coverage

Threshold: 0.959+
Effort: 1.0%
Coverage: 33.7%
Efficiency: 83.3%

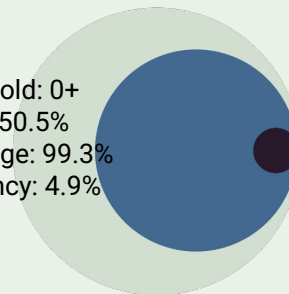


CVSS
7+
High

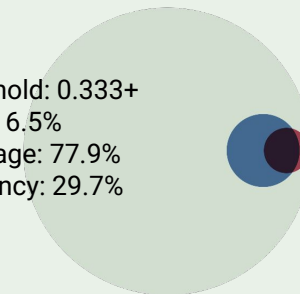
Threshold: 7+
Effort: 50.7%
Coverage: 78.5%
Efficiency: 3.8%



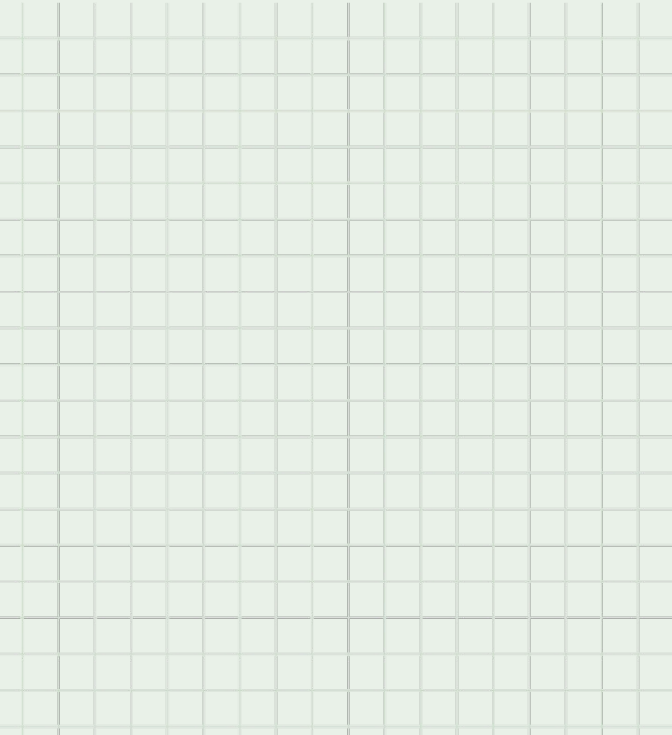
Threshold: 0+
Effort: 50.5%
Coverage: 99.3%
Efficiency: 4.9%



Threshold: 0.333+
Effort: 6.5%
Coverage: 77.9%
Efficiency: 29.7%



Roadmap



- What is the False Claims Act?
- What Are We Representing?
- Benchmarking Risk
- Benchmarking Yourself
- Representation Strategies

Double Edged Sword of Measurement

Measurement is Dual Use

A law that allows whistleblowers to sue in the name of the U.S., alleging fraud against the government.

Measure to Attest Truthfully

- DOJ often reiterates that they target misrepresentations, not breaches
- Knowledge (does not need to be intent) is an element of the FCA

Measurement as Evidence of Fraud

- Knowing of specific, downside risks and not reporting them likely satisfies the FCA's scienter requirement
- Testing for such risks and sitting on that information is...risky!

The Proposal

Redefine "adequate security" as a measurable, outcome-based standard rather than a binary control-implementation checklist.

What's required (data):

- Risk Model as Compliance Standard
- Recommended Thresholds
- Measure Compliance Against Existing Data

What's required (legally):

- Representations and openness with the government are key.
- Honest communications and updates of government stakeholders lowers risk
- Breaches do not necessarily lead to liability; nor does a lack of breach absolve liability .

EMPIRICAL



Thank You

Max Voldman Partner, Whistleblower Partners LLP
Michael Roytman CTO, Empirical Security